UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 1 slot(s). Supported theory: 23 slots. Placeholders: 0.
Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 15 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 1 computed, 23 supported by lecture slides, 0 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - computed - matches lecture slides 5-9 (Caesar shift 3 examples)

Question:

Using Caesar Cipher technique, decrypt the following ciphertext with a shift of 7 (replace each letter with the one 7 positions to the left).
KLCPJLYLABYULKHUKDPWLKVUL

Answer: DEVICERETURNEDANDWIPEDONE

Working:

```
K (10) -7 mod 26 -> D
L (11) -7 mod 26 -> E
C ( 2) -7 mod 26 -> V
P (15) -7 mod 26 -> I
J ( 9) -7 mod 26 -> C
L (11) -7 mod 26 -> E
Y (24) -7 mod 26 -> R
L (11) -7 mod 26 -> E
A ( 0) -7 mod 26 -> T
B ( 1) -7 mod 26 -> U
Y (24) -7 mod 26 -> R
U (20) -7 mod 26 -> N
L (11) -7 mod 26 -> E
K (10) -7 mod 26 -> D
H ( 7) -7 mod 26 -> A
U (20) -7 mod 26 -> N
K (10) -7 mod 26 -> D
D ( 3) -7 mod 26 -> W
P (15) -7 mod 26 -> I
W (22) -7 mod 26 -> P
L (11) -7 mod 26 -> E
K (10) -7 mod 26 -> D
V (21) -7 mod 26 -> O
U (20) -7 mod 26 -> N
L (11) -7 mod 26 -> E
```

Suggested marks: 1 mark for identifying the cipher/shift direction; 1 mark for the complete plaintext.
Confidence: computed - matches lecture slides 5-9 (Caesar shift 3 examples).

A1b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain substitution ciphers by describing how plain-text is transformed, what serves as the key, how the approach relates to Shannon's principle of confusion, and how this idea carries over to modern ciphers.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	State that substitution	"In substitution ciphers, we replace the plain-text letters with	031 - Classical Cryptography,	031 - Classical Cryptography::s0	1.00	supported (ste gate)

	replaces plain-text letters with other letters.	other letters"	slide 4	4::1		
2	Note that the transformed text produced by the replacement is the cipher-text.	"The resulting text is the cipher-text"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s0 4::1	0.33 LOW	supported
3	Identify the substitution rule as the key of the cipher.	"The substitution rule is the key"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s0 4::1	0.67	supported (ste gate)
4	Relate substitution to Shannon's principle of confusion.	"Corresponds to Shannon's principle of confusion"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s0 4::1	0.60	supported (ste gate)
5	Explain that the substitution idea is employed in modern ciphers.	"This idea is used in modern ciphers"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s0 4::1	0.60	supported (ste gate)
6	Contrast with Vigenere, which uses a keyword to select encrypting rows and resists simple frequency analysis.	"Use keyword to select encrypting rows"	031 - Classical Cryptography, slide 14	031 - Classical Cryptography::s1 4::1	0.40 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 031 - Classical Cryptography, slide 14; 031 - Classical Cryptography, slide 4

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) typical locations where IDS sensors are placed in a network-based IDS architecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A sensor can be positioned just inside the firewall.	"Just inside the firewall"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.50	supported (ste gate)
2	A sensor can be positioned on the DMZ.	"On the DMZ"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.25 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 062 - Intrusion Detection System, slide 7

A2b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six (6) preventive network security mechanisms that an organization can deploy to protect its network, explaining what each mechanism does.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A firewall controls incoming and outgoing network traffic according to predetermined security policies.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.80	supported (ste gate)
2	A proxy server improves data security and network performance by acting as a firewall and web filter, sharing network	"Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.79	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	connections and caching data.					
3	Network segmentation creates boundaries between network segments whose computing assets share a common function, risk or role.	"Boundaries between network segments where computing assets within the segment have a common function, risk or role within an organization."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.77	supported (ste gate)
4	A remote access VPN gives individual hosts or clients remote and secure access to the organization network.	"Provides remote and secure access to an organization network to individual hosts or clients"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.89	supported (ste gate)
5	Zero Trust Network Access (ZTNA) grants a user only the access and permission required to fulfil the user's role.	"A user should only has access and permission that required to fulfill the role"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.58	supported (ste gate)
6	Intrusion detection/prevention systems detect or prevent network attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4	061 - Network Security::s04::1	0.85	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) facts about the chain of trust in Trusted Computing, focusing on how it begins and how measurements are recorded.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The chain of trust begins at the hardware TPM and then proceeds through software stages such as RTM, TPM Software Stack, BIOS and kernel.	"The chain starts with the hardware TPM, then software: RTM,TPM Software Stack, BIOS, kernel"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.60	supported (ste gate)
2	Measurements taken during the chain are stored in Platform Configuration Registers (PCRs) on the TPM.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.60	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 8

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the roles of the two primary system components of the Next Generation Secure Computing Base, describing what each component is and how it supports trusted execution on the platform.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment

© Hak Cipta Universiti Teknologi MARA

1	Nexus is described as a special kernel that forms the core of the trusted operating environment.	"Special kernel (core of the trusted operating)"	073 - Trusted Computing, slide 13	073 - Trusted Computing::s13::1	0.62	supported (ste gate)
2	Nexus aims to isolate normal-mode processes from trusted-mode processes by placing them differently in memory.	"Isolate the process of normal mode and trusted mode differently in memory"	073 - Trusted Computing, slide 13	073 - Trusted Computing::s13::1	0.60	supported (ste gate)
3	Nexus provides functionality to authenticate and protect data that is entered, stored, communicated, and displayed by means of encryption.	"Authenticate and protect data (entered, stored, communicated, and displayed) by data encryption"	073 - Trusted Computing, slide 13	073 - Trusted Computing::s13::1	0.67	supported (ste gate)
4	Nexus acts as a security kernel that is authenticated at boot time.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.57	supported (ste gate)
5	Nexus authenticates trusted programs and provides the application interface to the TPM, without trusting the OS.	"Authenticates trusted programs"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.33 LOW	partly supporte
6	The Nexus Computing Agent is a trusted software component that runs in a trusted mode and communicates with Nexus.	"Trusted software component"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.25 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 13; 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List the TWO (2) stages that make up the biometric authentication process.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The identification stage, in which master characteristics are acquired, created and stored.	"Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.50	supported (ste gate)
2	The authentication stage, in which acquisition is repeated, followed by comparison and a decision.	"Authentication Stage Acquisition(s) Comparison Decision"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.71	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 5

A4b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State the definition of a biometric as given in the lecture, and state the TWO (2) sectors into which today's biometric applications are categorised. Then name the THREE (3) biometric technologies listed under the

© Hak Cipta Universiti Teknologi MARA

behavioural sector.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A biometric is defined as a physiological or behavioural characteristic of a human being that can distinguish one person from another and can theoretically be used for identification or verification of identity.	"A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of identity."	072 - Biometrics and Authentication, slide 2	072 - Biometrics and Authentication::s02::1	0.92	supported (ste gate)
2	The two sectors are the physiological sector and the behavioural sector.	"Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.33 LOW	partly supporte
3	The psychological sector covers iris, fingerprints, hand, retinal and face recognition.	"Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.78	supported (ste gate)
4	The behavioural sector covers voice, typing pattern and signature.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.67	supported (ste gate)
5	Biometric methods are listed as an alternative user authentication mechanism alongside smart cards and two-factor authentication.	"Alternative user authentication mechanisms are smart cards, biometric methods and two-factor authentication."	022 - Identification and Authentication, slide 24	022 - Identification and Authentication::s24::1	0.90	supported (ste gate)
6	An iris scan reads the unique pattern of the iris, which is coloured and visible from far, and requires no touch.	"Scans unique pattern of iris"	072 - Biometrics and Authentication, slide 10	072 - Biometrics and Authentication::s10::1	0.40 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 24; 072 - Biometrics and Authentication, slide 10; 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two characteristics of Trojan horse malware, including how it disguises itself and what harm it can cause once active on a host.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Trojan horses conceal their malicious purpose by presenting themselves as useful or benign software.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.00 LOW	supported
2	Once running, a Trojan can steal private data, delete files, capture keystrokes, or create a way for additional malware to be installed.	"begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.

Citations: 051 - Software Security, slide 12

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss six ways in which malware attacks and propagates, covering how malicious code is attached to executables, how early viruses and worms spread, how rootkits and spyware operate on infected hosts, and how self-replication supports propagation.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Malware can be attached to an executable by appending the virus body to a program.	"Append a virus body to a program"	051 - Software Security, slide 10	051 - Software Security::s10::1	0.50	supported (ste gate)
2	An executable can be infected by overwriting its program header so that the entry point switches to the virus.	"Over write a program header to switch the entry point to a virus"	051 - Software Security, slide 10	051 - Software Security::s10::1	0.60	supported (ste gate)
3	Early malware such as Elk Cloner spread through boot sector infection.	"A program spread via boot sector infection"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.40 LOW	partly supporte
4	The Morris worm propagated across the Arpanet by exploiting a debugging feature of sendmail for remote execution.	"Used a debugging feature of sendmail (remote execution)"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.40 LOW	partly supporte
5	Rootkits hide malicious processes and software so that the infected machine stays under the malware author's remote control.	"Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.54	supported (ste gate)
6	Spyware steals user logins and passwords, records visited sites and logs keystrokes to support identity theft.	"They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.61	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 7

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the difference between morals, ethics and laws as three forms of guidance for conduct in computer security work.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Morals are described as traditions of belief concerning right and wrong conduct, forming the basis of social behaviour.	"Morals are traditions of belief about right and wrong conduct"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.55	supported (ste gate)
2	Laws are formal rules of conduct imposed by a sovereign authority such as a government on its subjects or citizens.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	1.00	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 5

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain six requirements that a professional code of ethics and conduct, such as the ACM code, places on a computing professional's behaviour in security-related work.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The professional must aim for high quality in the processes and products of their professional work.	"Strive to achieve high quality in both the processes and products of professional work."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.75	supported (ste gate)
2	The professional must keep up high standards of competence, conduct and ethical practice.	"Maintain high standards of professional competence, conduct, and ethical practice."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.78	supported (ste gate)
3	The professional must be aware of and respect the rules that apply to their professional work.	"Know and respect existing rules pertaining to professional work."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.57	supported (ste gate)
4	The professional should contribute to society and human well-being, recognising all people as stakeholders in computing.	"Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.73	supported (ste gate)
5	The professional should avoid causing harm through their work.	"Avoid harm."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.29 LOW	supported
6	The professional should respect privacy and honour confidentiality.	"Respect privacy."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.33 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 12

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the Chinese Wall model as a formal access-control policy, stating the specific concern it addresses and how its access decisions depend on a subject's access history.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Chinese Wall policy is designed to address a specific concern: conflicts of interest involving a consultant or contractor.	"Brewer and Nash's Chinese Wall Policy is designed to address a very specific concern: conflicts of interest by a consultant or contractor."	024 - Formal Security Model, slide 27	024 - Formal Security Model::s27::1	0.91	supported (ste gate)
2	Access rights under the Chinese Wall change dynamically, since what a subject may access depends on the history of its past accesses.	"Notice that permissions change dynamically. The access rights that any subject enjoys depends on the history of past accesses"	024 - Formal Security Model, slide 24	024 - Formal Security Model::s24::1	0.61	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 24; 024 - Formal Security Model, slide 27

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Compare the access control matrix, access control lists and capability lists as structures for implementing access policies, and state the requirements that any such access control structure must satisfy.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The access control matrix is identified as one of the structures used to implement access policies.	"Access control structures are mechanisms for implementing access policies:"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.83	supported (ste gate)
2	Capability lists (C-List) are named as a structure for implementing access policies.	"Capabilities (C-List)"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.20 LOW	supported
3	Access control lists (ACL) are named as a structure for implementing access policies.	"access control lists (ACL)"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.50	supported (ste gate)
4	An access control structure must be able to express control policies.	"an ability to express control policies"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.43 LOW	supported
5	An access control structure must support verifiability of correctness.	"verifiability of correctness."	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.14 LOW	supported
6	An access control structure must provide scalability and manageability.	"scalability and manageability"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.29 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 023 - Access Control and Authorization, slide 7

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain what a buffer overflow is and how it can be exploited to hijack a program's execution flow.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A buffer overflow arises because the copy routine does not verify the length of the input string, so a longer string than the buffer can hold overflows it.	"strcpy() do not check the string length"	051 - Software Security, slide 23	051 - Software Security::s23::1	0.19 LOW	supported
2	Because bounds are not checked, the overflowing buffer content spills into the adjacent higher stack area, letting the attacker overwrite the	"By controlling buffer content, an attacker can overwrite the return address with an arbitrary value and hijack the execution flow."	051 - Software Security, slide 21	051 - Software Security::s21::1	0.41 LOW	partly supporte

© Hak Cipta Universiti Teknologi MARA

	return address with an arbitrary value and divert execution.					

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 21; 051 - Software Security, slide 23

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six Windows security mechanisms or components and, for each, briefly indicate the security function it performs.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Security Reference Monitor operating in kernel mode performs ACL verification.	"Security Reference Monitor: ACL verification"	041 - Windows Security, slide 3	041 - Windows Security::s03::1	0.44 LOW	partly supporte
2	The winlogon process in user mode handles user logon.	"Log-on process (winlogon): user logon"	041 - Windows Security, slide 3	041 - Windows Security::s03::1	0.67	supported (ste gate)
3	The Local Security Authority verifies and changes passwords and manages access tokens and audit logs.	"Local Security Authority (LSA): password verification and change, access tokens, audit logs"	041 - Windows Security, slide 3	041 - Windows Security::s03::1	0.82	supported (ste gate)
4	The Security Accounts Manager holds the accounts database and performs password encryption.	"Security Accounts Manager (SAM): accounts database, password encryption"	041 - Windows Security, slide 3	041 - Windows Security::s03::1	0.75	supported (ste gate)
5	User Account Control enforces limited user privileges.	"User Account Control (UAC, Vista): enforcement of limited user privileges"	041 - Windows Security, slide 3	041 - Windows Security::s03::1	1.00	supported (ste gate)
6	Active Directory acts as an LDAP-like directory service for organising system resources such as users, groups and security policies.	"Active directory introduced in Windows 2000 is an LDAP-like directory service for organization of system resources:"	041 - Windows Security, slide 6	041 - Windows Security::s06::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 041 - Windows Security, slide 3; 041 - Windows Security, slide 6

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State two classes of threats to a computer system and, for each, identify the security objective whose violation represents the harm caused.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Disclosure is a threat class involving unauthorized access to information, harming confidentiality.	"Disclosure - unauthorized access to information"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.44 LOW	partly supporte
2	Deception is a threat class involving acceptance of false data, harming integrity.	"Deception - acceptance of false data"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.44 LOW	partly supporte

© Hak Cipta Universiti Teknologi MARA

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 10

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe the Samy worm as a case study of a cross-site scripting attack, covering how the malicious script was injected, how it spread to other users, and the outcome of the incident.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The worm injected JavaScript into a user profile by writing to document.body.innerHTML.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.70	supported (ste gate)
2	It obtained the list of the user's friends (heros) by issuing a GET request to a user profile.	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.38 LOW	supported
3	It added Samy as a friend by performing XML-HTTP requests against the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.70	supported (ste gate)
4	Any visitor to an infected profile had their own profile and friends list infected, which is how the worm propagated.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.33 LOW	supported
5	The incident ultimately infected about one million MySpace profiles.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15	052 - Web Security::s15::1	0.43 LOW	supported
6	The underlying weakness is that any web application returning user input without filtering is a potential XSS vulnerability, allowing arbitrary JavaScript to run in the victim's browser.	"Any web application that returns user input without filtering is a potential XSS vulnerability!"	052 - Web Security, slide 13	052 - Web Security::s13::1	0.53	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List two ways in which an intrusion detection system can support the detection and defence against attacks on a computer system.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	An IDS can confirm whether an attack succeeded or failed by examining host-based IDS log entries.	"Verifies success or failure of attack by reviewing HIDS log entries"	062 - Intrusion Detection System, slide 14	062 - Intrusion Detection System::s14::1	0.25 LOW	supported
2	A passive detection system can log events	"Can take passive action (logging and alerting) when an attack is	062 - Intrusion Detection	062 - Intrusion Detection	0.46 LOW	supported

© Hak Cipta Universiti Teknologi MARA

	and raise alerts once an attack has been identified.	identified"	System, slide 29	System::s29::1		

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 062 - Intrusion Detection System, slide 14; 062 - Intrusion Detection System, slide 29

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Explain how the distinction between a threat and an attack, together with the role of vulnerabilities, shapes the countermeasures a security team should deploy against malware and other threat classes.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A threat is only a potential violation of security, so countermeasures must anticipate danger before any actual breach occurs.	"Threats: A threat is a "potential" violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.29 LOW	partly supporte
2	An attack is the actual violation of security, so countermeasures must also detect and respond once exploitation happens.	"Attacks: The actual violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.33 LOW	partly supporte
3	Because a threat is an entity representing constant danger to an asset, countermeasures must be continuous rather than one-off.	"Threat: object, person, or other entity representing a constant danger to an asset"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.46 LOW	partly supporte
4	Because an attack deliberately exploits a vulnerability, patching or removing weaknesses is itself a countermeasure.	"Attack: a deliberate act that exploits vulnerability"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.40 LOW	partly supporte
5	Protection of assets must combine prevention, detection and response techniques rather than relying on a single control.	"Protection of assets encompasses prevention, detection and response techniques"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.46 LOW	supported
6	Countermeasures should follow defense-in-depth and a layered security architecture so that one failed layer does not expose the asset.	"The key design principles of computer security are defense-in-depth and layered security architecture"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.39 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 28; 011 - Introduction to Computer Security, slide 9

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A software house is drafting a code of ethics for its security team. A junior developer asks why the team cannot simply rely on the ACM code, and a manager wants to know what such a documented code can and cannot

© Hak Cipta Universiti Teknologi MARA

achieve for the group.

Question:

Explain what a documented code of ethics provides to a professional group, and discuss the limitations such a code has when guiding the ethical conduct of its members.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A code of ethics is a written record of the behaviours that a professional or social group considers acceptable.	"Documented set of acceptable behaviors for professional or social groups."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.40 LOW	supported
2	The code is established by the group itself rather than imposed from outside.	"Defined by the group."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.12 LOW	supported
3	The code spells out which particular actions are acceptable and which are not.	"Identifies specific actions as appropriate or inappropriate."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.14 LOW	supported
4	A limitation is that the code may fail to capture the ethical views held by every individual in the group.	"May not reflect the ethical of every member of the group."	071 - Ethics and Computer Security, slide 9	071 - Ethics and Computer Security::s09::1	0.36 LOW	supported
5	Another limitation is that the code often cannot be enforced, since it is a code of conduct and not a legal document.	"Many times it isn't enforceable. It's a code of conduct, not a legal document."	071 - Ethics and Computer Security, slide 9	071 - Ethics and Computer Security::s09::1	0.55	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 6; 071 - Ethics and Computer Security, slide 9

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Referring to the scenario, explain five ethical concerns the security team's code of ethics should address when handling personal information, and why the organization itself, not only individual developers, must take responsibility for protecting that information.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The code should require the team to protect individuals' personal information as a privacy obligation.	"Protecting one's personal information"	071 - Ethics and Computer Security, slide 13	071 - Ethics and Computer Security::s13::1	0.30 LOW	partly supporte
2	The code should address the accuracy of information, covering authentication and fidelity of the data held.	"Deals with authentication and fidelity of information"	071 - Ethics and Computer Security, slide 13	071 - Ethics and Computer Security::s13::1	0.30 LOW	supported
3	The code should settle who owns information about individuals and how it may be sold or exchanged.	"Deals with who owns information about individuals and how information can be sold and exchanged"	071 - Ethics and Computer Security, slide 13	071 - Ethics and Computer Security::s13::1	0.64	supported (ste gate)
4	The code should define what information a person has a right to obtain about others and how it may be used.	"Deals with what information a person has the right to obtain about others and how the information can be used"	071 - Ethics and Computer Security, slide 13	071 - Ethics and Computer Security::s13::1	0.64	supported (ste gate)
5	The organization should adopt a recognized professional code of ethics and conduct,	"Association of Computing Machinery ACM (founded 1947) has a code of ethics and professional conduct."	071 - Ethics and Computer Security, slide 7	071 - Ethics and Computer Security::s07::1	0.39 LOW	partly supporte

© Hak Cipta Universiti Teknologi MARA

	such as the ACM code, as the basis for its own responsibility.					

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 13; 071 - Ethics and Computer Security, slide 7

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A system administrator is reviewing how the Linux servers in a campus laboratory protect user accounts. She wants to strengthen the controls applied to password files and login behaviour, and is also concerned about how passwords are stored in encrypted form.

Question:

State FIVE (5) password security controls that can be applied to protect user accounts, and state how a password is stored in encrypted form.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Access control should be applied to password files.	"Access control applied to password files"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.67	supported (ste gate)
2	Accounts should be de-activated after multiple failed login attempts.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.75	supported (ste gate)
3	The time of the last login should be displayed to the user.	"Displaying the time of a last login"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.67	supported (ste gate)
4	Password policies should be defined, for example for the root password.	"Password policies, e.g. for root password"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.50	supported (ste gate)
5	The password is stored in encrypted form using a one-way hash function.	"Password is stored in an encrypted form using a one-way hash function:"	022 - Identification and Authentication, slide 8	022 - Identification and Authentication::s08::1	1.00	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 12; 022 - Identification and Authentication, slide 8

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Referring to the scenario, the administrator considers deploying Kerberos and single sign-on so that laboratory users authenticate once and are not burdened by repeated password entry. Discuss the motivation for single sign-on and the design criteria that Kerberos must satisfy, and explain how a user's password is used at login.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Single sign-on reduces the burden of remembering many passwords.	"Reduce the need to memorize passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.29 LOW	supported

2	Single sign-on reduces the time users spend typing passwords.	"Reduce the time spent on typing passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.43 LOW	supported
3	Kerberos must be secure against eavesdropping, so no password is sent in clear text.	"Security against eavesdropping: no password transmission in clear text."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.67	supported (ste gate)
4	Kerberos must be transparent, so the user is unaware of any authentication beyond the initial login.	"Transparency: user is not aware of any authentication beyond an initial login."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.70	supported (ste gate)
5	At login the hash of the user's password becomes the client's secret key.	"The hash value of his password KU = h(P) becomes a secret key of the client/user."	022 - Identification and Authentication, slide 19	022 - Identification and Authentication::s19::1	0.86	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 18; 022 - Identification and Authentication, slide 19

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA